

Continuous Control Assurance Framework (CCAF)

A Nonproprietary Synthetic Demonstration for Financial and Digital-Payment Environments

Ayodele Timothy Adeniyi, CISA, ACA
Version 1.3.1 | July 16, 2026 | Apache License 2.0

Purpose. CCAF addresses a practical assurance task: turning selected access, change-management, logging, reconciliation, and payment-monitoring objectives into repeatable tests over authorized records. It identifies conditions for review and preserves the population, configuration, exceptions, and run evidence needed for a reviewer to understand and reproduce the work.

How to read this summary

1. Run	How CCAF validates records, executes tests, reports results, and preserves evidence.
2. Test	What the three modules examine and how rule-based and comparison procedures differ.
3. Interpret	What the synthetic demonstration showed and what its counts, rates, and priorities mean.
4. Adopt	What an institution must authorize, validate, investigate, and govern before operational use.

20	9	20,300	168
control tests	source datasets (SHA-256 manifest)	eligible control evaluations	reported exceptions

Evidence boundaries

- The repository contains seeded synthetic data and independently written documentation and code; no employer, client, or production material was used.
- All results describe the fixed synthetic demonstration: full-population means every row of the supplied in-scope extract, and detection of planted conditions is regression evidence, not a production accuracy rate.
- The 20 tests are a bounded reference set, not a comprehensive catalog, and complement rather than replace enterprise security, GRC, and audit platforms.
- No institutional adoption, external validation, or endorsement by any referenced organization is claimed.

1. How a CCAF Run Works

A run follows a sequence that a reviewer can inspect and repeat: validate the supplied records, execute the approved tests, report the conditions identified, and preserve the evidence of what was performed.

1. Validate	2. Evaluate	3. Report	4. Preserve
Check schemas, keys, timestamps, values, and selected relationships.	Apply versioned rule-based tests and comparison procedures.	Record status, eligible population, exceptions, and review priority.	Retain hashes, configuration, calibration, and run metadata.

Why validation comes first

Every result depends on the supplied records. A Critical or High data-quality finding stops the run before any control test executes. Prior outputs are cleared at the start of the run so an unsuccessful execution cannot leave stale exception files that appear current.

Framework checks	Practitioner evidence still required
Required files and fields; empty extracts; key completeness and uniqueness; timestamps; selected values and relationships.	Queries or reports used to generate the extracts; filters and period coverage; expected counts or totals; owner review and reconciliation.

The resulting source-assurance record declares what was supplied and what remains unresolved. File hashes preserve file identity after extraction; they do not establish that the extraction was complete or correctly scoped.

Two possible test outcomes

Status	Meaning	How it is reported
Completed	The required records and analytical conditions were present.	Eligible population, exceptions, and rate may be reported.
Not Evaluable	A required analytical condition was absent.	Reason is reported and the exception rate remains blank.

A Not Evaluable test cannot appear as a clean zero-exception result. For every completed test, the framework reports the population actually eligible for that procedure so the result retains its denominator and scope.

Configuration and reproducibility

Operational assumptions are stored outside the code in `config/defaults.json` and written to the run's calibration record. They include dates, activity windows, thresholds, minimum comparison populations, aging rules, tolerances, and review-priority weights. An institution must approve and test its own settings; bundled values are demonstration defaults.

2. What the Framework Tests

The 20 tests form a bounded reference set across three modules. They were selected to demonstrate how access, technology-operations, and payment-control objectives can be translated into transparent, repeatable procedures. The set is not a complete control catalog.

Module	Tests	Records examined	Examples of conditions identified
Privileged Access	PA-01 to PA-07 (7 tests)	User status, access grants, and authentication activity	Access after termination or expiry, missing or self-approval, dormant access, entitlement conflicts, and unusual after-hours activity
Change and Logging	CM-01 to CM-07 (7 tests)	Change records, deployment events, and log-source heartbeats	Missing approval or test evidence, incompatible duties, unlinked deployments, unreviewed emergency changes, rate shifts, and logging gaps
Reconciliation and Payments	TR-01 to TR-06 (6 tests)	Ledger and processor-settlement records	Unmatched or aged items, amount differences, duplicate identifiers, unusual velocity, and activity below an approval limit

How the procedures decide

Most tests inspect each eligible record against a documented rule. For example, PA-07 reperforms the expiry check across active temporary privileged grants to determine whether any grant remained active after its approved expiry. Three procedures instead compare behavior across a supplied population:

Test	Comparison	Minimum analytical condition
PA-06	After-hours authentication counts across active privileged users	At least 30 active privileged users and usable variation
CM-06	Recent emergency-change rate against an earlier baseline	10 recent changes, 30 baseline changes, and a nonzero baseline emergency count
TR-05	Recent transaction counts across active accounts	At least 30 active accounts and usable variation

PA-06 and TR-05 use the median and median absolute deviation so a few extreme observations do not distort the comparison baseline. Every reported exception is a lead for investigation, not a confirmed control deviation, deficiency, intent, or culpability.

Where the detailed work program lives

The complete practitioner procedure for each test - including its risk statement, intended control condition, eligible population, evidence examined, follow-up steps, tailoring points, and limitation - is documented in docs/control-test-catalog.md.

3. What the Demonstration Showed

The generator plants and labels 165 known test conditions. Automated regression tests detected 165 of 165 planted conditions across all 20 control tests in this fixed synthetic scenario. The run also reported 3 additional peer-comparison observations. Because ordinary synthetic background records can satisfy a comparison rule, those observations require review and are not automatically classified as errors or false positives.

Module	Planted	Detected	Detected %	Additional observations
Privileged Access	39	39	100%	1
Change and Logging	49	49	100%	0
Reconciliation and Payments	77	77	100%	2

How to read counts and rates

Each test reports exceptions per 1,000 eligible records or entities. Module summaries add the eligible populations of only Completed tests and report exceptions per 1,000 eligible evaluations. These rates provide review context; they are not incident rates, error rates, or institution-level risk ratings.

Module	Total	Completed	Not eval.	Evaluations	Exceptions	Per 1,000
M1 Privileged Access	7	7	0	2,120	40	18.87
M2 Change & Logging	7	7	0	1,654	49	29.63
M3 Reconciliation & Payments	6	6	0	16,526	79	4.78

What the output looks like

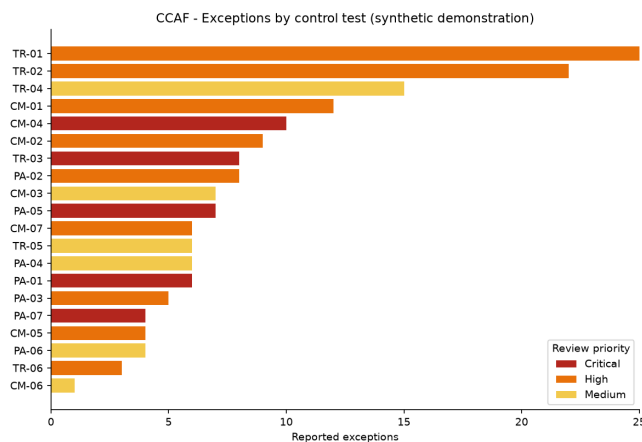


Figure 1. Exceptions by control and review priority.

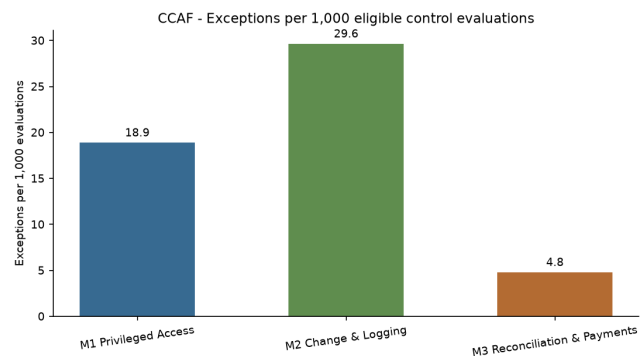


Figure 2. Exceptions per 1,000 eligible control evaluations.

Review-priority score

Review-priority score = configurable review-priority weight x exposure factor (1.0-2.0). It orders follow-up work within the demonstration. It is not a loss probability, compliance rating, confirmed deficiency, or empirically calibrated risk score.

4. Moving from Exception to Institutional Use

A reported exception is the beginning of professional judgment, not the end of it. CCAF identifies the coded condition and preserves the evidence needed for follow-up; authorized personnel make the later determinations.

Stage	Meaning
1. Automated exception	The coded condition was met in the supplied eligible records.
2. Investigated condition	A reviewer examined supporting records and relevant context.
3. Confirmed deviation	The applicable control requirement was not performed as designed.
4. Deficiency or finding	Authorized personnel evaluated the deviation under the institution's methodology.

Where CCAF fits

Assurance stage	Responsibility
Before execution	Define the risk and control objective, confirm implementation, authorize access, establish source reliability, and approve configuration.
CCAF execution	Apply the procedure, report status and eligible population, identify exceptions, and preserve run evidence.
After execution	Investigate and disposition exceptions, determine remediation or escalation, and assess later changes for rollforward.

Phased implementation

Phase	Required work
0 - Authorize	Approve scope, data access, schemas, thresholds, calendars, review-priority definitions, and escalation.
1 - Pilot	Inspect authorized historical records, inquire regarding each exception, determine its disposition, assess reviewer effort, and calibrate.
2 - Operationalize	Schedule authorized runs, integrate ticketing/GRC, apply retention and access controls, and monitor drift.
3 - Govern	Obtain required approvals, train a second operator, revalidate after changes, and contribute only nonconfidential improvements.

Framework traceability

Module	Primary relevance	Interpretive boundary
Privileged Access	NIST CSF PR.AA/GV.RR; FFIEC access administration; PCI DSS 7/8/10	Supports evidence organization; does not establish compliance.
Change and Logging	NIST CSF PR.PS/DE.CM/DE.AE; FFIEC development and operations; PCI DSS 6/10	Test outputs require institutional scope and adjudication.
Reconciliation and Payments	FFIEC payment-system reconciliation and integrity topics; supporting NIST detection relationships	NIST/PCI entries are supporting relationships, not direct reconciliation requirements.

Governance artifacts

A successful run creates the input hash manifest, source-assurance record, data-quality report, structured exception records, per-test evaluation summaries, calibration record, run metadata, and planted-condition verification summary. The demonstration leaves independent row-count and control-total reconciliation unresolved for all 9 datasets. Adopting institutions must complete those fields, define retention and remediation requirements, and preserve exception dispositions.

5. Boundaries, References, and Release Record

Limitations

- Synthetic verification demonstrates software behavior only for the fixed planted scenario; it does not establish production accuracy, adoption, or loss reduction.
- Source-extract completeness, field mapping, privacy, holiday calendars, expected activity, and thresholds must be validated locally; file hashes alone do not establish completeness.
- The framework is not a complete cybersecurity, fraud, anti-money-laundering, audit, or compliance program.
- Reference SQL uses database-dependent boolean, interval, and timestamp patterns and must be adapted and tested on the target platform.
- No agency, standards body, employer, client, examiner, or independent reviewer is represented as endorsing this version.

Authoritative references

1. NIST, **The Cybersecurity Framework (CSF) 2.0**, NIST CSWP 29 (2024), <https://doi.org/10.6028/NIST.CSWP.29>.
2. NIST, **Information Security Continuous Monitoring**, SP 800-137 (2011), <https://doi.org/10.6028/NIST.SP.800-137>.
3. FFIEC, **Cybersecurity Assessment Tool Sunset**, <https://www.ffiec.gov/cyberassessmenttool.htm>. FFIEC states that it does not endorse a particular replacement tool.
4. FFIEC, **Information Technology Examination Handbook InfoBase**, <https://ithandbook.ffiec.gov/>.
5. PCI Security Standards Council, **PCI DSS v4.x**, <https://www.pcisecuritystandards.org/standards/pci-dss/>.
6. U.S. Securities and Exchange Commission, rules implementing Sarbanes-Oxley Act Section 404 internal-control reporting requirements.
7. The Institute of Internal Auditors, **GTAG: Continuous Auditing and Monitoring, 3rd Edition** (2025), <https://www.theiia.org/en/content/guidance/recommended/supplemental/gtags/continuous-auditing-and-monitoring>.

Repository package

The package includes source code, planted-condition data and labels, JSON configuration, a source-metadata template, automated tests, reference SQL, source-assurance and run artifacts, generated exceptions and summaries, dashboards, a 20-test practitioner catalog, governance and implementation documents, Apache-2.0 license, changelog, version file, and citation metadata. This release summary is reproducible from `scripts/build_methodology_pdf.py`; the detailed method is documented in `docs/methodology.md`.

Release status: Version 1.3.1 is a maintenance release prepared on July 16, 2026, superseding version 1.3.0. Repository: <https://github.com/Ayodele-Adeniyi/continuous-control-assurance-framework>. Version tag: <https://github.com/Ayodele-Adeniyi/continuous-control-assurance-framework/tree/v1.3.1>. SHA-256 of `docs/methodology.md`: `8ff7fc91d970ee8e2068cbe95876baa5fd6fca2991e10a7af33fb238ec3e31b5`. No institutional adoption, agency endorsement, or external validation is claimed.

For independent verification, see `REVIEWER_GUIDE.md` in the public repository.